POL-008 – Politica de control al accesului și management al identităților

Politica stabilește cine poate accesa ce informații și sisteme StormGuard, cum se dovedește identitatea și cum se acordă, se revizuiesc și se retrag drepturile

1. Scop, domeniu de aplicare și obiective

1.1 Scop

Politica asigură că fiecare acces la informațiile StormGuard este făcut de o persoană identificată, cu o autentificare puternică și doar în limita drepturilor de care are nevoie rolul său. Într-un studio de jocuri, un singur cont compromis sau un drept uitat poate expune codul sursă, build-urile nelansate, SDK-urile primite sub NDA de la producătorii de console sau datele financiare. Politica reduce acest risc prin trei reguli de bază: identitate unică, acces minim necesar și ciclu de viață controlat al drepturilor.

1.2 Domeniu de aplicare

Identități: conturile celor 48 de angajați, conturile administrative ale departamentului IT, conturile de urgență, conturile de serviciu, conturile de oaspete ale colaboratorilor externi și identitățile dispozitivelor.

Sisteme:

- identitatea centrală: Active Directory on-premises și Microsoft Entra ID, sincronizate prin Entra Cloud Sync;
- producția: Perforce P4, Jenkins, P4 Code Review, Unreal Game Sync, folderele SDK de console, portalurile producătorilor de console;
- colaborarea: Microsoft 365 (Exchange, SharePoint, OneDrive, Teams), Confluence, Jira, Adobe, Autodesk;
- infrastructura: servere, hipervizor, firewall și VPN, switch-uri, NAS, Veeam și depozitul hardened, Wazuh;
- zona financiară: programul de contabilitate, internet banking, SPV ANAF și RO e-Factura;
- accesul fizic: carduri pentru sediu, camera tehnică, camera devkit-urilor și biroul Financiar.

Politica nu acoperă conturile jucătorilor din jocurile publicate; cerințele pentru acestea sunt în POL-017 (dezvoltare securizată).

1.3 Obiective de securitate

Obiectivele detaliază obiectivul general O2 (acces controlat) din SG-ISMS-POL-000 și susțin O1 (protejarea proprietății intelectuale). Fiecare are KPI-uri în secțiunea 4.

Obiectiv	Ce urmărim	Obiectiv din Politica generala
A1 – Identitate unică și trasabilă	Fiecare acțiune poate fi legată de o persoană; nu există conturi partajate sau anonime pentru oameni	O2, O6
A2 – Autentificare puternică	Toate conturile au MFA, de preferință rezistent la phishing; accesul vine doar de pe dispozitive conforme	O2, O3
A3 – Acces minim necesar	Drepturile se acordă doar prin grupuri, cu aprobarea proprietarului activului, și acoperă doar ce cere rolul	O1, O2
A4 – Ciclu de viață controlat	Accesul se acordă la timp la angajare, se ajustează la schimbarea rolului și se retrage în aceeași zi la plecare	O2
A5 – Privilegii administrative limitate și supravegheate	Puține conturi administrative, separate de cele zilnice, jurnalizate și verificate independent	O2, O3
A6 – Drepturi revizuite și demonstrabile	Revizuiri periodice finalizate la termen, cu dovezi pentru audit	O6

2. Cerințe de control al accesului

Active Directory este sursa autoritară pentru conturi și grupuri, iar Entra ID preia autentificarea în cloud. Orice acces care nu respectă cerințele de mai jos este o excepție și urmează procesul de excepții (PR-14).

2.1 Principii

1. **Need-to-know și minim privilegiu:** accesul se acordă doar pentru ce cere rolul, nu „pentru orice eventualitate”.
2. **Acces implicit refuzat:** ce nu este acordat explicit este interzis.
3. **Acces doar prin grupuri:** drepturile se dau grupurilor AD sincronizate, niciodată direct utilizatorului.
4. **Aprobarea proprietarului:** Lead-ul care deține activul aprobă accesul; IT implementează; CISO verifică.
5. **Separarea atribuțiilor:** cine cere nu aprobă, cine aprobă nu implementează pentru sine; plățile au dublă autorizare.
6. **Zero încredere implicită în rețea:** accesul se decide pe baza identității, a dispozitivului și a contextului, nu doar a faptului că utilizatorul este în birou.

2.2 Tipuri de conturi

Tip	Cine	Reguli
Cont standard	Fiecare angajat	Nominal, unul per persoană; creat din AD și sincronizat în Entra ID; MFA obligatoriu
Cont administrativ (adm-nume)	Cei 3 membri IT	Separat de contul zilnic; fără e-mail și fără navigare web; folosit doar de pe stațiile administrative; chei FIDO2
Cont de urgență (break-glass)	2 conturi cloud-only	Global Administrator, excluse din Conditional Access; parole în plic sigilat în seif; orice autentificare alertează CISO și CEO; testate semestrial
Cont de serviciu	Jenkins, Veeam, Perforce, integrări	Documentat cu proprietar; fără autentificare interactivă; parolă lungă în seiful de secrete sau gMSA; revizuit trimestrial
Cont de oaspete (Entra B2B)	Consultantul juridic, alți colaboratori aprobați	MFA; acces doar la resursele contractate; expirare la 6 luni, reînnoită doar la cerere

Tip	Cine	Reguli
Cont local de administrator pe stații	—	Parolă unică, rotită automat (Windows LAPS); folosit doar de IT
Conturi partajate pentru oameni	—	**Interzise.** Excepție: conturi impuse de producători (de ex. anumite portaluri de devkit), cu proprietar nominal, parolă în managerul de parole și jurnal de utilizare

2.3 Autentificare

Cerință	Regulă
MFA	Obligatoriu pentru toți și pentru toate sistemele care îl suportă: Entra ID, VPN, Perforce, Jenkins, portalurile de console, internet banking, SPV ANAF. Metode: Microsoft Authenticator cu number matching, Windows Hello for Business; chei FIDO2 pentru administratori. SMS doar ca metodă de recuperare temporară
Dispozitiv conform	M365, Atlassian, Adobe, VPN și aplicațiile financiare doar de pe stații Intune conforme; telefoanele personale doar prin aplicații protejate (POL-002)
Single sign-on	Aplicațiile noi se integrează cu Entra ID (SAML/OIDC) sau cu AD (LDAP) înainte de a intra în producție
Parole	Minimum 14 caractere, verificate cu Entra Password Protection; fără expirare periodică forțată; schimbare obligatorie la suspiciune de compromitere; păstrate doar în managerul de parole
Protocoale vechi	POP, IMAP, SMTP AUTH și autentificarea de bază dezactivate
Context	Autentificări permise din UE; excepții pentru deplasări, cu termen; autentificările riscante sunt blocate sau cer reautentificare
Sesiuni	Ecran blocat după 10 minute; sesiunile VPN și cele administrative au durată limitată; revocarea sesiunilor la plecare sau la compromitere
Blocarea contului	Blocare temporară după încercări repetate eșuate; deblocare doar după verificarea identității (PR-07)

2.4 Acordarea accesului

Accesul se acordă pe baza matricei de, cu grupuri pe rol (de ex. SG-Prod-Programming, SG-Prod-Art, SG-Prod-QA, SG-Finance, SG-Platform-NDA, SG-IT-Admins). Matricea este documentul de referință. Orice acces în afara ei cere aprobare separată și se revizuiește la următoarea revizuire.

Zonă	Proprietar care aprobă	Cerință suplimentară
Perforce: cod, design, artă, narativ, audio	Lead-ul departamentului	Protections table pe grupuri; QA doar citire build-uri

Zonă	Proprietar care aprobă	Cerință suplimentară
SDK-uri și materiale NDA de console (SG-Platform-NDA)	Lead Programmer + Game Master	NDA de platformă semnat; persoane nominalizate la producător; revizuire trimestrială
Jenkins	Lead Programmer	Administrare doar Build Engineer și IT
Date financiare, programul de contabilitate, internet banking	Responsabilul Financiar + CEO	Roluri separate pentru inițiere și autorizare a plăților (POL-020)
Date de personal (site HR)	HR	Doar HR și CEO
Infrastructură și conturi administrative	CEO pentru IT Lead; IT Lead pentru ceilalți	
Acces fizic (camera tehnică, camera devkit-urilor, birou Financiar)	IT Lead, Game Master, respectiv responsabilul Financiar	Card nominal; jurnal de acces păstrat cel puțin 90 de zile

2.5 Conturi privilegiate

- Drepturile administrative se împart pe rol: IT Lead și IT Infra au Domain Admin; IT Lead și conturile de urgență au Global Administrator; IT Suport are doar roluri Entra limitate (Intune, User, Helpdesk, License Administrator).
- Drepturile privilegiate ale IT Lead sunt aprobate de CEO; ale celorlalți, de IT Lead.
- Model pe niveluri: conturile care administrează AD nu se autentifică pe stațiile utilizatorilor.
- Utilitarele care pot ocoli controalele rulează doar din conturi adm-, pe stațiile administrative, și sunt jurnalizate.
- Acțiunile administrative din AD, Entra ID, Perforce, firewall și Veeam sunt colectate în Wazuh, exportate zilnic într-o stocare imuabilă pe care IT nu o poate modifica și revizuite trimestrial; acțiunile IT Lead sunt verificate de auditorul extern.
- Elevarea temporară a drepturilor pe stații urmează POL-002 PR-04.

2.6 Colaboratori externi și parteneri

- Colaboratorii primesc cont de oaspete doar după semnarea NDA și a POL-003, la cererea HR, cu expirare.

- Actorii de voce și studiourile externe nu primesc conturi; primesc doar linkuri nominale, cu expirare.
- Publisherul nu primește conturi în sistemele interne; build-urile pleacă doar prin canalul agreat.
- Accesul tehnic al furnizorilor (mentenanță, suport) este temporar, supravegheat de IT și închis la final.

2.7 Frecvența revizuirilor de acces

Ce se revizuiește	Frecvență	Cine revizuiește
SG-IT-Admins, SG-IT-Support, conturile de urgență și de serviciu	Trimestrial	CEO (pentru IT) și IT Lead
Perforce, SG-Platform-NDA, Jenkins	Trimestrial	Lead-urile, cu IT Lead
SG-Finance, programul de contabilitate, internet banking	Trimestrial	CEO + IT Lead
Conturile de oaspete	Trimestrial	HR + IT Suport
Restul grupurilor (M365, Confluence, Jira, SharePoint)	Semestrial	Lead-urile, cu IT Lead
Drepturile de acces fizic	Semestrial	IT Lead + Front Desk

3. Atribuții pe roluri organizaționale

Controlul accesului funcționează doar dacă cererea, aprobarea, implementarea și verificarea sunt făcute de persoane diferite. Abrevieri: **IT Lead** = IT Manager Lead (CISO); **IT Infra** = IT Manager – Infrastructură; **IT Suport** = IT Manager – Stații și suport.

3.1 Cine face ce, pe etape

Etapă	Cere	Aprobă	Implementează	Verifică
Cont nou (angajat)	HR	Lead-ul departamentului (grupurile)	IT Suport (cont, stație); IT Infra (Perforce, Jenkins)	IT Lead
Acces suplimentar	Angajatul sau Lead-ul	Proprietarul activului	IT Suport sau IT Infra	IT Lead, la revizuire
Acces la SDK-uri de console	Lead Programmer	Lead Programmer + Game Master	IT Infra	IT Lead, trimestrial
Acces financiar	Responsabilul Financiar	CEO	IT Infra (program), banca și ANAF (la cererea Financiar)	CEO + IT Lead, trimestrial
Drepturi administrative IT Manageri	IT Lead	IT Lead	IT Infra	CEO, trimestrial; auditorul extern
Drepturi administrative IT Lead	IT Lead	CEO	IT Infra	Auditorul extern
Plecare	HR	—	IT Suport, IT Infra, Front Desk, Financiar	IT Lead

3.2 Atribuții pe rol

Rol	Atribuții în aplicarea POL-008	KPI (sec. 4)
CEO	Aprobă politica și excepțiile; aprobă drepturile privilegiate ale IT Lead și accesul la datele financiare; revizuiește trimestrial conturile IT și drepturile financiare; păstrează credențialele stocării imuabile a jurnalelor; primește alertele de folosire a conturilor de urgență	K9, K10, K11
IT Lead (CISO)	Proprietarul politicii și al matricei de acces; aprobă drepturile administrative ale celor doi IT Manageri; definește politicile Conditional Access; organizează și urmărește revizuirile de	K9–K12

Rol	Atribuții în aplicarea POL-008	KPI (sec. 4)
	acces; revizuiește trimestrial jurnalele administrative; tratează excepțiile și incidentele de acces; raportează KPI-urile	
IT Infra	Administrează AD (grupuri, GPO, controlere de domeniu), Entra Cloud Sync, autentificarea LDAP pentru Perforce, Jenkins și NAS, protections table din Perforce, VPN-ul, contul Veeam și conturile de serviciu; aplică drepturile în sistemele de producție și financiare; retrage drepturile excesive găsite la revizuire	K4, K12
IT Suport	Creează, modifică și dezactivează conturile în Entra ID și M365; înrolează MFA și Windows Hello; administrează Intune și LAPS, conturile de oaspete și licențele; verifică identitatea la resetarea parolei sau a MFA; dezactivează conturile inactive; nu are drepturi de Domain Admin sau Global Administrator	K1–K3, K5–K8, K13
HR	Declanșează angajarea, schimbarea de rol și plecarea în Jira, la termen; confirmă semnarea NDA și a POL-003 înainte de activarea contului; cere și reînnoiește conturile de oaspete; este sursa autoritară pentru lista angajaților activi	K6, K7, K13
Front Desk	Emite și dezactivează cardurile de acces conform profilurilor aprobate; recuperează cardurile la plecare și cardurile temporare ale vizitatorilor; semnalează cardurile pierdute	K7, K11
Lead-uri de departament (proprietari de active)	Aprobă grupurile pentru membrii echipei și accesul la folderele lor din Perforce, SharePoint și Confluence; revizuiesc trimestrial sau semestrial drepturile echipei și semnează rezultatul; anunță HR și IT la orice schimbare de rol	K5, K11, K12
Game Master	Aprobă, împreună cu Lead Programmer, accesul la SDK-uri și materiale NDA; ține lista persoanelor nominalizate la producătorii de console și o aliniază cu grupul SG-Platform-NDA; aprobă accesul la site-ul de livrare către publisher	K11
Build Engineer	Proprietarul conturilor de serviciu Jenkins și al credențialelor din Jenkins Credentials; nu folosește conturi personale în joburi	K1
Departamentul Financiar	Cere accesul la program, la internet banking și la SPV doar pentru persoane nominale; separă rolurile de inițiere și autorizare; anunță banca și ANAF la plecarea unui titular; nu împrumută token-urile	K7, K11
Toți angajații	Folosesc doar contul propriu; activează MFA și Windows Hello; nu partajează parole sau coduri; resping cererile MFA pe care nu le-au inițiat și le raportează; cer acces doar pentru ce le trebuie	K2, K3
Colaboratori externi	Folosesc doar contul de oaspete primit, cu MFA; notifică încheierea colaborării și incidentele în 24 de ore	K13

Rol	Atribuții în aplicarea POL-008	KPI (sec. 4)
Auditorul intern extern	Verifică anual drepturile și acțiunile conturilor IT, inclusiv ale IT Lead, și un eșantion de revizuiri de acces	K10, K11

4. KPI

Cei 13 indicatori acoperă toate cele șase obiective. Se raportează trimestrial CEO-ului, și se revizuiesc anual la analiza de management. Majoritatea se extrag automat din Entra ID, AD, Intune și Wazuh.

Cod	Indicator	Țintă	Obiectiv	Sursă date	Responsabil	Frecvență
K1	Conturi nominale sau documentate cu proprietar (umane, de serviciu, de oaspete); conturi partajate neaprobate	100%; 0	A1	Export AD și Entra ID vs. lista HR și registrul conturilor de serviciu	IT Suport	Lunar
K2	Conturi cu MFA activ (Entra ID, VPN, Perforce, Jenkins, portaluri de console, internet banking); conturi administrative cu chei FIDO2	100%; 100%	A2	Raport metode de autentificare Entra ID; inventarul cheilor	IT Suport	Lunar
K3	Utilizatori care folosesc o metodă MFA rezistentă la phishing (Authenticator cu number matching, Windows Hello, FIDO2), fără SMS ca metodă principală	≥ 95%	A2	Entra ID	IT Suport	Trimestrial
K4	Drepturi atribuite direct unui utilizator, în afara grupurilor	0	A3	Script de verificare AD, Perforce, SharePoint	IT Infra	Trimestrial
K5	Cereri de acces cu aprobarea proprietarului documentată în Jira	100%	A3	Jira (eșantion lunar de 10 cereri)	IT Suport	Lunar
K6	Angajați noi cu cont, MFA și acces pregătite în prima zi de lucru	≥ 95%	A4	Jira (data cererii vs. data activării)	HR + IT Suport	Lunar

Cod	Indicator	Țintă	Obiectiv	Sursă date	Responsabil	Frecvență
K7	Conturi, carduri și acces financiar revocate în aceeași zi lucrătoare la plecare	100%	A4	Jira, Entra ID, controlul accesului	HR + IT Suport	Lunar
K8	Conturi inactive de peste 45 de zile dezactivate (exclus: concedii documentate)	100%	A4	Entra ID, AD	IT Suport	Lunar
K9	Numărul de conturi privilegiate	3 conturi adm- + 2 de urgență; Domain / Global Admin doar IT Lead și IT Infra	A5	AD, Entra ID (roluri)	IT Lead	Trimestrial
K10	Autentificări cu conturile de urgență și acțiuni administrative neexplicate, investigate și închise	100% investigate; 0 neexplicate la revizuire	A5	Wazuh, stocarea imuabilă a jurnalelor	IT Lead; CEO pentru IT Lead	Trimestrial
K11	Revizuiri de acces finalizate la termen	100%	A6	Formularele de revizuire semnate	Lead-uri + IT Lead	Trimestrial
K12	Drepturi excesive găsite la revizuire și retrase în 5 zile lucrătoare	100%	A6	Jira	IT Infra + IT Suport	Trimestrial
K13	Conturi de oaspete active cu NDA valabil și expirare setată; conturi expirate eliminate	100%	A4	Entra ID, dosarele HR	HR + IT Suport	Trimestrial

Cum se citesc indicatorii

K7 și K10 sunt cei mai importanți pentru riscul de scurgere: un cont rămas activ după plecare sau o acțiune administrativă neexplicată se tratează ca incident (POL-021). O țintă ratată două trimestre la rând duce la o acțiune corectivă înregistrată în Jira.

5. Procese legate de politică

Politica este pusă în practică prin 18 procese, grupate pe patru zone. Cererile și aprobările trec prin Jira, ca fiecare pas să aibă o dovadă verificabilă la audit.

5.1 Ciclul de viață al identității

Cod	Proces	Declanșator	Deținător	Rezultat / dovadă
PR-01	Angajare (joiner)	Cerere HR în Jira, cu cel puțin 3 zile înainte	HR, cu IT Suport și IT Infra	Grupuri aprobate de Lead; cont activat doar după NDA și POL-003 semnate; MFA înrolat la primul login
PR-02	Schimbare de rol (mover)	Decizie HR sau a Lead-ului	HR, cu Lead-urile vechi și noi	Drepturile vechi retrase în aceeași zi în care se acordă cele noi
PR-03	Plecare planificată (leaver)	Notificare HR, cel târziu în ultima zi	HR, cu IT Suport, IT Infra, Front Desk, Financiar	Cont dezactivat, sesiuni revocate, workspace-uri Perforce șterse, card și token-uri recuperate, acces la bancă și SPV retras; proces-verbal
PR-04	Plecare imediată sau încetare cu risc	Decizie CEO sau HR	IT Lead, cu HR	Revocare în cel mult o oră, înainte de comunicarea către persoană; verificarea ultimelor acțiuni în Wazuh și Perforce
PR-05	Conturi de oaspete: creare, reînnoire, expirare	Cerere HR pentru un colaborator	HR + IT Suport	Cont B2B cu MFA și expirare la 6 luni; reînnoire doar cu NDA valabil
PR-06	Cerere de acces suplimentar	Tichet Jira de la angajat sau Lead	Proprietarul activului; IT implementează	Formularul F-01 aprobat; membru adăugat în grup, nu direct pe resursă

5.2 Autentificare și credențiale

Cod	Proces	Declanșator	Deținător	Rezultat / dovadă
PR-07	Resetarea parolei sau a MFA și deblocarea	Cerere a utilizatorului; cont blocat	IT Suport	Identitate confirmată față în față sau prin apel video cu act și confirmare de la Lead; niciodată doar pe baza unui e-mail sau a unui apel

Cod	Proces	Declanșator	Deținător	Rezultat / dovadă
	contului, cu verificarea identității			
PR-08	Înrolarea MFA, Windows Hello și a cheilor FIDO2	Cont nou; dispozitiv nou; cheie pierdută	IT Suport	Metodă rezistentă la phishing activă; cheile FIDO2 ale administratorilor în inventar, câte două per persoană
PR-09	Gestionarea parolelor și a secretelor partajate	Cont nou; secret nou de echipă; suspiciune de compromitere	IT Lead	Secretele în managerul de parole sau în seiful de secrete, cu acces nominal; rotire la plecarea unei persoane care le cunoștea

5.3 Acces privilegiat

Cod	Proces	Declanșator	Deținător	Rezultat / dovadă
PR-10	Acordarea și retragerea drepturilor administrative	Angajare sau schimbare în IT; proiect care cere drepturi temporare	IT Lead; CEO pentru IT Lead	Cont adm- cu drepturile aprobate; drepturile temporare expiră automat
PR-11	Folosirea și testarea conturilor de urgență	Indisponibilitatea autentificării normale; test semestrial	IT Lead, cu CEO	Jurnalul F-04 completat; parolă schimbată și plic resigilat după folosire
PR-12	Gestionarea conturilor de serviciu	Sistem sau integrare nouă; revizuire trimestrială	IT Infra, cu proprietarul sistemului	Intrare în registrul F-03 (scop, proprietar, drepturi, rotire); gMSA unde se poate
PR-13	Revizuirea jurnalelor administrative	Calendar trimestrial; alertă Wazuh	IT Lead; CEO și auditorul pentru acțiunile IT Lead	Raport de revizuire semnat; abaterile deschise ca incident

5.4 Revizuire, excepții și incidente

Cod	Proces	Declanșator	Deținător	Rezultat / dovadă
PR-14	Cererea de excepție de la politică	Nevoie de acces care nu respectă cerințele (de ex. cont partajat impus de un producător)	IT Lead (evaluare), CEO (aprobare)	Formularul F-05; intrare în registrul de excepții, cu termen de cel mult 12 luni și controale compensatorii
PR-15	Revizuirea periodică a drepturilor de acces	Calendarul din sec. 2.7	IT Lead organizează; Lead-urile și CEO revizuiesc	Formularul F-02 semnat; drepturile excesive retrase în 5 zile lucrătoare
PR-16	Integrarea unei aplicații noi cu SSO și grupuri	Aplicație nouă aprobată	IT Suport sau IT Infra, cu proprietarul aplicației	Aplicație legată de Entra ID sau AD, cu roluri pe grupuri și adăugată în matricea de acces
PR-17	Răspuns la compromitere a unui cont	Alertă de autentificare riscantă; raport al utilizatorului; MFA aprobat fără cerere	Membrul IT de gardă; IT Lead	Sesiuni revocate, parolă și MFA resetate, activitatea verificată, incident înregistrat
PR-18	Revizuirea anuală a politicii și a matricei de acces	Analiza de management; schimbare de structură sau sistem critic nou	IT Lead	Versiune nouă aprobată de CEO; matricea de acces actualizată

Formulare și registre asociate:

F-01 Cerere de acces;

F-02 Formular de revizuire a drepturilor;

F-03 Registrul conturilor de serviciu;

F-04 Jurnalul de folosire a conturilor de urgență;

F-05 Cerere de excepție. Pașii detaliați ai fiecărui proces se scriu în procedurile operative, după aprobarea politicii.